



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <https://capstone-vigil.dns.net.za>

Generated on Wed, 2 Sept 2026 16:28:27

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	3
Informational	3

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	241
Low	Warning		ZAP warnings logged - see the zap. log file for details	67
Info	Informational	http://staging.capstone-vigil.dns.net.za	Percentage of responses with status code 3xx	100 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of responses with status code 2xx	74 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of responses with status code 3xx	11 %
Info	Informational		Percentage of	14 %

		https://capstone-vigil.dns.net.za	responses with status code 4xx	
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with content type application/javascript	51 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with content type font/woff2	3 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with content type image/x-icon	3 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with content type text/css	9 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with content type text/html	9 %
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of endpoints with method GET	100 %
Info	Informational	https://capstone-vigil.dns.net.za	Count of total endpoints	31
Info	Informational	https://capstone-vigil.dns.net.za	Percentage of slow responses	13 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of responses with status code 2xx	72 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of responses with status code 3xx	10 %

Info	Exceeded Low	https://staging.capstone-vigil.dns.net.za	Percentage of responses with status code 4xx	13 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of responses with status code 5xx	2 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with content type application/javascript	57 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with content type font/woff2	3 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with content type image/x-icon	3 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with content type text/css	9 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with content type text/html	15 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Percentage of endpoints with method GET	100 %
Info	Informational	https://staging.capstone-vigil.dns.net.za	Count of total endpoints	33
Info	Exceeded Low	https://staging.capstone-vigil.dns.net.za	Percentage of slow responses	26 %

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	3
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	3
Strict-Transport-Security Header Not Set	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Content-Type Header Missing	Informational	Systemic
Re-examine Cache-control Directives	Informational	3
User Controllable HTML Element Attribute (Potential XSS)	Informational	1

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://capstone-vigil.dns.net.za/
Node Name	https://capstone-vigil.dns.net.za/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/api
Node Name	https://capstone-vigil.dns.net.za/api
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/login?next=%2Frobots.txt
Node Name	https://capstone-vigil.dns.net.za/login (next)
Method	GET
Attack	
Evidence	
Other Info	
Instances	3

Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	https://capstone-vigil.dns.net.za/
Node Name	https://capstone-vigil.dns.net.za/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/api
Node Name	https://capstone-vigil.dns.net.za/api
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/login?next=%2F
Node Name	https://capstone-vigil.dns.net.za/login (next)
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
------------	--

Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	https://capstone-vigil.dns.net.za/
Node Name	https://capstone-vigil.dns.net.za/
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://capstone-vigil.dns.net.za/api
Node Name	https://capstone-vigil.dns.net.za/api
Method	GET
Attack	
Evidence	X-Powered-By: Express
Other Info	
URL	https://capstone-vigil.dns.net.za/login?next=%2Fsitemap.xml
Node Name	https://capstone-vigil.dns.net.za/login (next)
Method	GET
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Strict-Transport-Security Header Not Set
------------	---

Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.

URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0caa74im9j.x-.js
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0caa74im9j.x-.js
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0plsp7r.vl.33.js
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0plsp7r.vl.33.js
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0z8nnro42ldra.css
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0z8nnro42ldra.css
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/_next/static/media/5c285b27cdda1fe8-s.p.0yo6-5yoeedq.woff2
Node Name	https://capstone-vigil.dns.net.za/_next/static/media/5c285b27cdda1fe8-s.p.0yo6-5yoeedq.woff2
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/favicon.ico?favicon.0_k6qh-31fgyo.ico
Node Name	https://capstone-vigil.dns.net.za/favicon.ico (favicon.0_k6qh-31fgyo.ico)
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers

Reference	https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0caa74im9j.x-.js
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0caa74im9j.x-.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0plsp7r.vl.33.js
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0plsp7r.vl.33.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://capstone-vigil.dns.net.za/_next/static/chunks/0z8nnro42ldra.css
Node Name	https://capstone-vigil.dns.net.za/_next/static/chunks/0z8nnro42ldra.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://capstone-vigil.dns.net.za/_next/static/media/5c285b27cdda1fe8-s.p.0yo6-5yoeedq.woff2
Node Name	https://capstone-vigil.dns.net.za/_next/static/media/5c285b27cdda1fe8-s.p.0yo6-5yoeedq.woff2
Method	GET

Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://capstone-vigil.dns.net.za/favicon.ico?favicon.0_k6qh-31fgyo.ico
Node Name	https://capstone-vigil.dns.net.za/favicon.ico (favicon.0_k6qh-31fgyo.ico)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Content-Type Header Missing
Description	The Content-Type header was either missing or empty.
URL	https://capstone-vigil.dns.net.za/
Node Name	https://capstone-vigil.dns.net.za/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/module-management
Node Name	https://capstone-vigil.dns.net.za/module-management
Method	GET
Attack	
Evidence	
Other Info	

URL	https://capstone-vigil.dns.net.za/robots.txt
Node Name	https://capstone-vigil.dns.net.za/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/sitemap.xml
Node Name	https://capstone-vigil.dns.net.za/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/solver
Node Name	https://capstone-vigil.dns.net.za/solver
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure each page is setting the specific and appropriate content-type value for the content being delivered.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
CWE Id	345
WASC Id	12
Plugin Id	10019

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://capstone-vigil.dns.net.za/
Node Name	https://capstone-vigil.dns.net.za/
Method	GET
Attack	
Evidence	s-maxage=31536000
Other Info	
URL	https://capstone-vigil.dns.net.za/api

Node Name	https://capstone-vigil.dns.net.za/api
Method	GET
Attack	
Evidence	
Other Info	
URL	https://capstone-vigil.dns.net.za/login?next=%2Frobots.txt
Node Name	https://capstone-vigil.dns.net.za/login (next)
Method	GET
Attack	
Evidence	s-maxage=31536000
Other Info	
Instances	3
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	https://capstone-vigil.dns.net.za/login?next=%2Fchedules
Node Name	https://capstone-vigil.dns.net.za/login (next)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://capstone-vigil.dns.net.za/login?next=%2Fchedules appears to include user input in: a(n) [a] tag [href] attribute The user input found was: next=/chedules The user-controlled value was:

	/schedules
Instances	1
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031